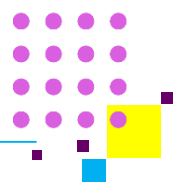




第五章 云计算安全

2022年春



目 录

CONTENTS

- 5.1 云计算安全基础知识
- 5.2 云计算安全技术
- 5.3 云计算安全标准
- 5.4 云计算安全法律法规



5.1 云计算安全基础知识

5.1.1 什么是云安全

5.1.2 云安全的威胁

5.1.3 云安全的机遇

5.1 云计算系统安全的基础

- 云计算安全(或简称“云安全”)的问题层出不穷



隐私信息在网上泄漏。

authy.com
coinbase.com
bitcoin.de
betterment.com
transferwise.com
prosper.com
patreon.com
bitpay.com
news.ycombinator.com
producthunt.com
medium.com
4chan.org
yelp.com
okcupid.com
zendesk.com(Zendesk post and updates | no leaked data found)
uber.com
poloniex.com
localbitcoins.com
kraken.com
23andme.com
curse.com(and some other Curse sites likeminecraftforum.net)
counsyl.com
tfl.gov.uk
myaccount.nytimes.com
technicpack.net
cloudflare.com
blockchain.info
discordapp.com(affected)
digitalocean.com(no leaked data found in several search engine caches)
namecheap.com(no leaked data found in several search engine caches)
glassdoor.com(no leaked data found in several search engine caches)
vultr.com(no leaked data found in several search engine caches)
fastmail.com(not affected,#2)
1password.com(not affected)
Alexa Top 10,000 on Cloudflare DNS:
upwork.com
codepen.io
fiverr.com
thepiratebay.org
extratorrent.com
getbootstrap.com
jquery.com
laravel.com
laracasts.com
seriouseat.com
bitdefender.com
ziprecruiter.com
glassdoor.com
pastebin.com
fitbit.com
discordapp.com
change.org
feedly.com(affected)
ircloud.com

部分受影响的
网站列表

5.1.1 什么是云安全

- 云计算安全

概念：云计算安全 指的是为了保护云环境中的数据、应用程序、以及逻辑和物理层面上的基础设施而制定或实施的策略和技术手段。

- 安全即服务

概念：安全即服务 也是一类重要的服务模式,它指的是云服务提供商为用户提供基于云的安全服务。



5.1.1 什么是云安全

- 云安全理解

- 用户角度

云安全是数据的安全和隐私的保护

- 云平台角度

云安全涉及数据的存储和传输安全、数据的合法访问、用户身份认证和防止恶意攻击等

- 云计算的虚拟化角度

云安全关注虚拟化特权提升、虚拟机隔离机制破坏和虚拟环境信息泄漏等。



5.1.1 什么是云安全

- 云安全在不同的场景下往往对应的含义

云计算的三种服务模型,包括**软件即服务**(Software as a Service, **SaaS**)、**平台即服务**(Platform as a Service, **PaaS**)、**基础设施即服务**(Infrastructure as a Service, **IaaS**),云安全对参与云计算的各个实体分配了不同的安全职责。



不同服务模型下的安全职责

5.1.1 什么是云安全

- 云安全在不同的场景下往往对应的含义

服务模型	含义
SaaS	在这种服务模型下,云服务提供商负责几乎所有的安全性,因为云用户只能访问和管理其使用的应用程序,并且无法更改应用程序。云服务提供商需要在提供服务的同时解决安全问题来消除云用户的顾虑。
PaaS	在这种服务模型下,云服务提供商负责平台的安全性,而用户负责他们在平台上所部署的应用,包括所有安全配置。可以看出在这个服务模型下,整个系统的安全性需要通过云服务提供商和用户之间执行各自的安全职责来协同维护。
IaaS	相比于前两种服务模型,该服务模型下的用户需要对于安全性承担更多责任。例如,在IaaS中,云服务提供商需要更多地承担虚拟平台隔离、通信安全以及数据与记录备份等。而用户在PaaS模型中,还要考虑抵御云服务器本身的偷窥威胁。

5.1.1 什么是云安全

- 云安全与传统信息安全的异同点

	传统安全	云安全
针对对象	针对的是用户可以掌控的“安全区域”（例如个人电脑、网站服务器等），所保护的对象也都处于用户可以掌控的范围内。	用户的数据、应用程序等都存储或运行在云平台上，而云平台则是用户无法掌控的区域。如何保证用户信息不被其他用户甚至是云服务提供商恶意访问，是云计算安全中十分重要并亟待解决的关键性问题之一。
安全技术	所面临的诸如软件漏洞、网络病毒、黑客攻击及信息泄漏等信息系统中普遍存在的共性问题，都会在云安全中有充分地体现。	云计算的发展也带来了新安全技术的发展或诞生。例如，云平台中虚拟化技术的广泛使用使得虚拟化的安全问题凸显出来，也带来了虚拟化安全技术的大力发展；云计算场景下对加密数据处理的需求，也在一定程度上刺激了密文计算技术的发展。
服务模式	传统服务中数据分散，用户享受服务的成本高，性价比低。	云计算引入了全新的多租户、数据集中、软硬件资源集中的服务模型。这种服务模型使得包括个人和企业在内的用户能够以较低的价格获得十分稳健和优异的存储或计算服务，同时也会带来新的安全需求。

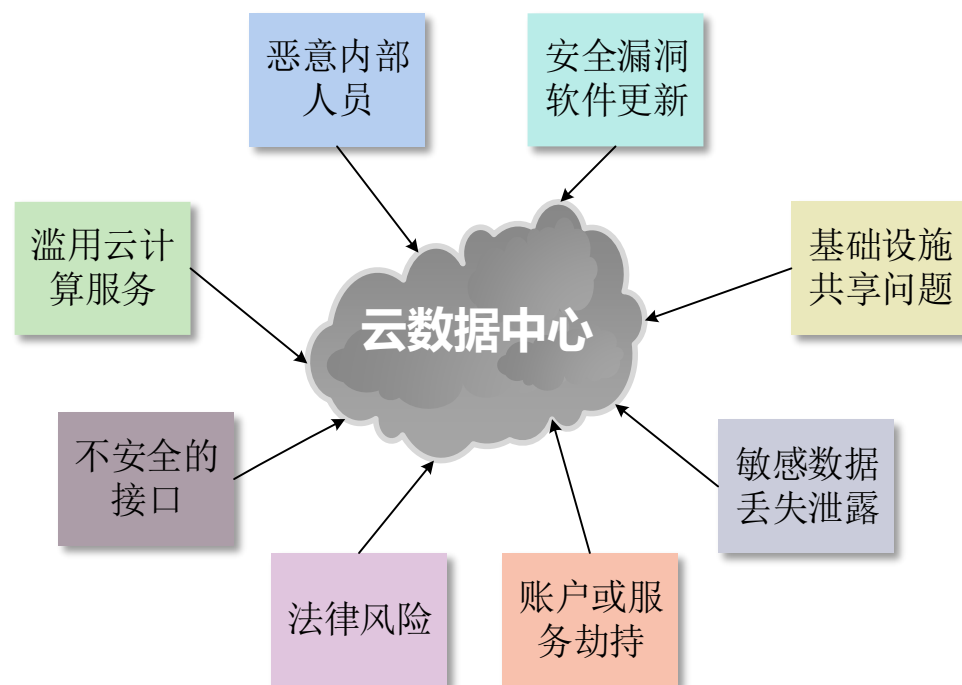
5.1.1 什么是云安全

- 云安全问题越来越多地被暴露出来



5.1.2 云安全的威胁

- 云计算带来新的安全威胁



云数据中心面临的安全威胁

- 具体表现在以下几个方面:

- 一、由物理计算资源共享带来的虚拟机安全问题;
- 二、由数据的拥有者与数据之间的物理分离带来的用户数据隐私保护与云计算可用性之间的矛盾;
- 三、用户行为隐私问题;
- 四、云计算服务的安全管理方面的问题。

5.1.2 云安全的威胁

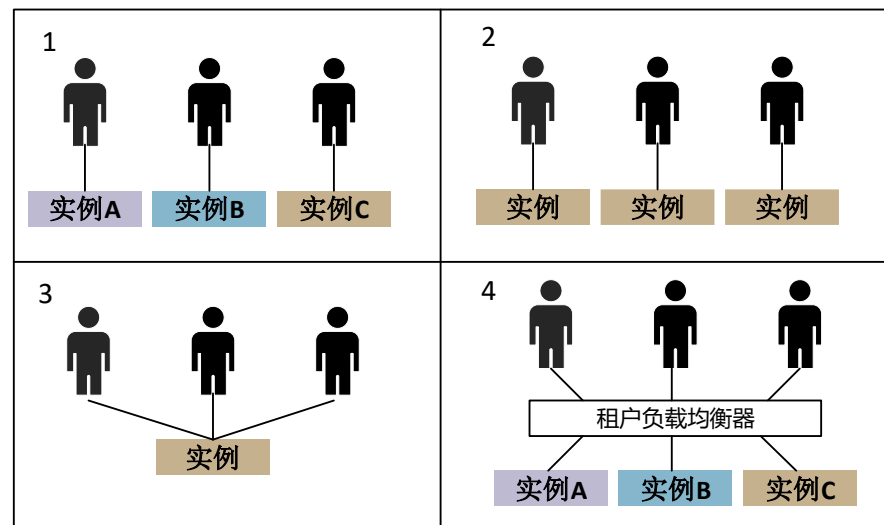
- 虚拟化技术安全威胁

虚拟化技术是在云计算中心实现计算与存储资源高效共享的核心技术。该技术使得云计算相对于传统计算方式具有两个关键的特点：**多租户** (multi-tenancy) 和**快速弹性** (rapid elasticity), 而它们都带来了额外的安全威胁。

- 多租户带来的威胁

多租户 表示用户需要与其他租户分享计算资源、存储资源、服务和应用；

方式3和4是具有安全风险的。所有租户同时存在于相同的进程和硬件中, 这样的资源共享会严重地影响租户在云中的信息安全性。



多租户的实现方式示例

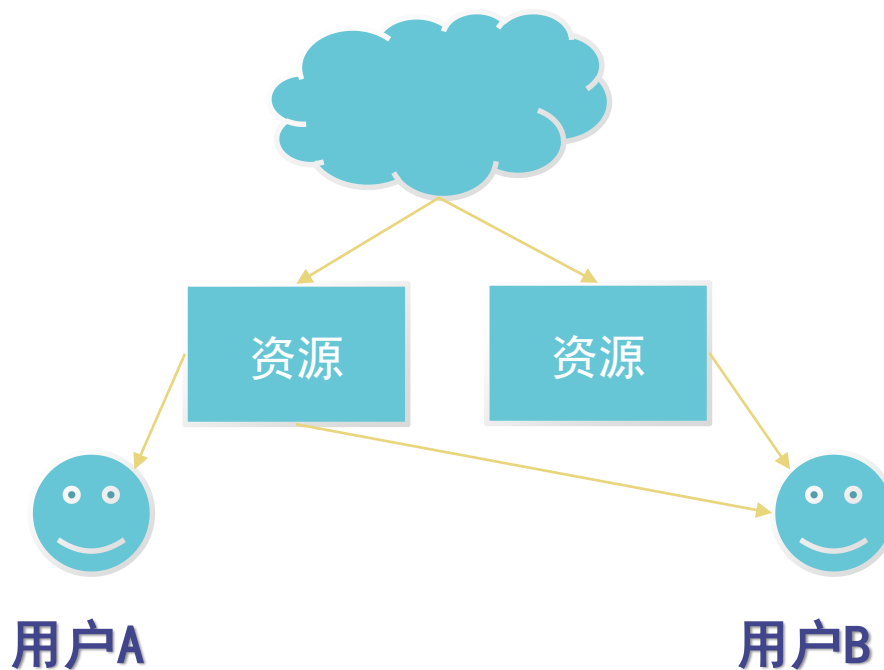
5.1.2 云安全的威胁

- 虚拟化技术安全威胁

虚拟化技术是在云计算中心实现计算与存储资源高效共享的核心技术。该技术使得云计算相对于传统计算方式具有两个关键的特点：**多租户** (multi-tenancy) 和**快速弹性** (rapid elasticity), 而它们都带来了额外的安全威胁。

- 快速弹性带来的威胁

快速弹性 是说云服务提供商可以根据当前的需求动态调整分给每个服务的资源, 这也意味着租户有机会使用之前被分配给其他租户的资源, 这样就会导致机密性的问题。



5.1.2 云安全的威胁

- 虚拟机存在的相关安全问题

- 虚拟机自身安全
- 虚拟机镜像安全
- 虚拟网络安全
- 虚拟机监控器安全



5.1.2 云安全的威胁

• 数据管理失控

在云计算中,用户对放置在远程云计算中心的数据和计算失去物理控制,对于自身的数据是否收到保护、计算任务是否被正确执行等都不能确定,由此带来了新的安全问题。数据安全问题包括 **存储数据安全**、**剩余数据安全** 和 **传输数据安全** 等。

• 存储数据安全

存储数据安全 考虑的是用户存储在云上的数据的安全性。

- 许多用户直接将网络数据存储在云端,很少有人使用加密的方法手段对数据进行保护;
- 在发生安全事故时,云服务提供商很难能够及时告知用户,用户也就无法对数据进行及时的处理;
- 一些云服务提供商可能为了商业利益和名誉而对数据的丢失或者篡改等隐而不报,这会对用户数据隐私和用户数据的完整性造成极大的安全威胁;
- 如果预先用传统密码体制加密,云计算中心基本上就无法对密文做任何有意义的计算。



5.1.2 云安全的威胁

- 数据管理失控

在云计算中,用户对放置在远程云计算中心的数据和计算失去物理控制,对于自身的数据是否收到保护、计算任务是否被正确执行等都不能确定,由此带来了新的安全问题。数据安全问题包括 **存储数据安全**、**剩余数据安全** 和 **传输数据安全** 等。

- 剩余数据安全

剩余数据安全 问题是指,用户在使用完云存储服务后退租或动态释放部分资源时,如果只是对用户磁盘中的文件做简单的删除,而下一次将磁盘空间（逻辑卷）重新分配给其他租户时,可能会被恶意租户使用数据恢复软件读出磁盘数据,从而导致先前租户的数据泄漏。



5.1.2 云安全的威胁

- 数据管理失控

在云计算中,用户对放置在远程云计算中心的数据和计算失去物理控制,对于自身的数据是否收到保护、计算任务是否被正确执行等都不能确定,由此带来了新的安全问题。数据安全问题包括 **存储数据安全**、**剩余数据安全** 和 **传输数据安全** 等。

- 传输数据安全

传输数据安全 是指数据在传输过程中可能被窃取或篡改。服务商需要通过有效的手段,防止传输数据被窃取或篡改,需要保证数据即使丢失也不易泄密。针对用户未采用加密手段的情况,服务商也应有相应强度的加密措施,保证用户数据在网络传输中的机密性和完整性,同时保证传输的可用性。



5.1.2 云安全的威胁

- 云平台安全管理挑战

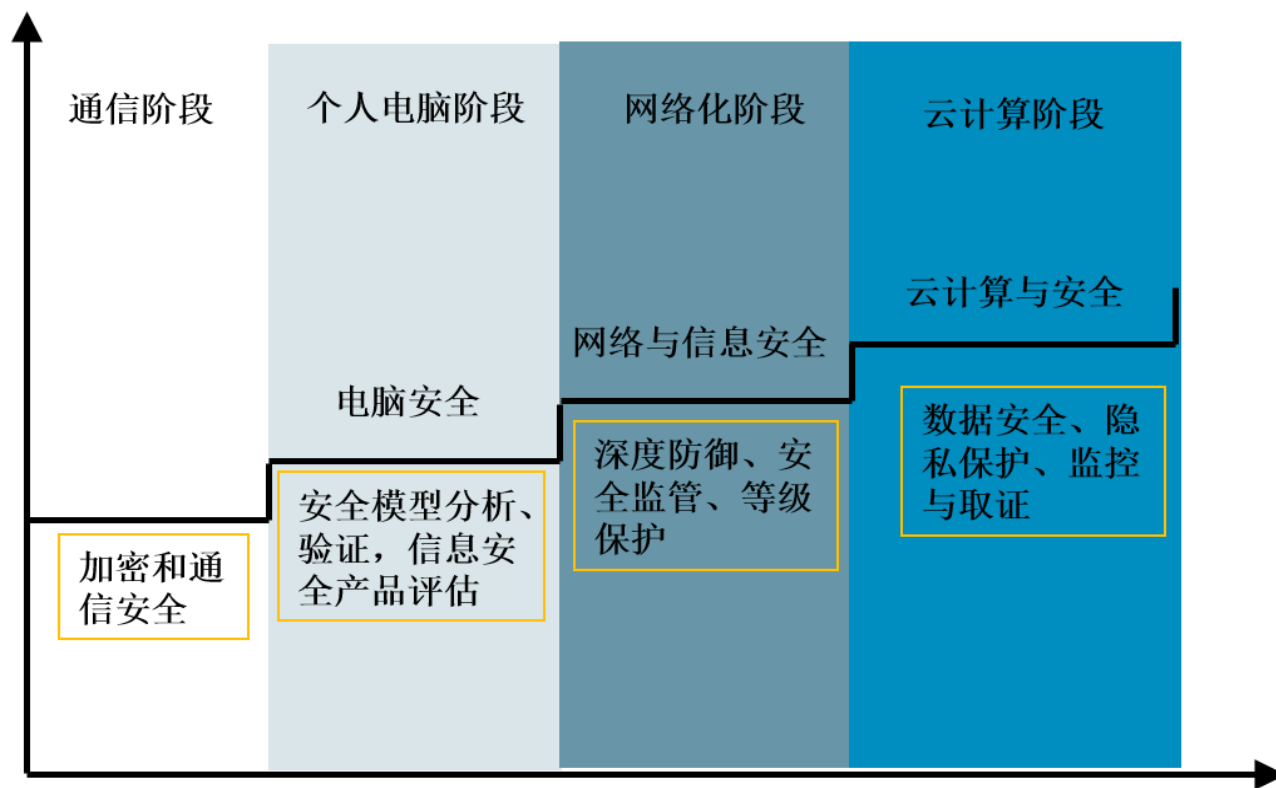
对于安全的需求越高,所需付出的代价也就越大; 技术只是手段,管理才是根本,信息安全保障依赖“三分技术,七分管理”,信息安全管理覆盖了信息系统的整个生命周期。据统计,有超过半数的安全事件源于内部人员。尽管大多数组织都有可能存在恶意企图的内部人员,但在云计算模式下这种风险会增大。

云安全联盟总结的云安全威胁

数据泄漏	高级持续性威胁
身份、凭证和访问管理不足	数据丢失
不安全的接口和应用程序编程接口	调查不足
系统漏洞	滥用和恶意使用云服务
账户劫持	拒绝服务
恶意的内部人员	共享的技术漏洞

5.1.3 云安全的机遇

- 信息安全各阶段的发展进程



信息安全技术发展阶段图

5.1.3 云安全的机遇

- 云计算给安全技术创新和发展带来了机遇

01

整合资源

云服务提供商将数据中心中多个虚拟化集群资源池统一整合为规格更大的逻辑资源池。

02

提供平台

云服务通过网络提供各种客户平台,如手机、笔记本电脑、平板电脑等,使用标准化机制接入网络,使用云服务。

03

高效利用资源

用户数据存储在数据中心,云计算系统通过使用附加的测量能力,实现对资源的自动控制和优化。



5.2 云计算安全技术

5.2.1 云系统虚拟化安全

5.2.2 云数据存储与计算安全

5.2.3 安全即服务

5.2.1 云系统虚拟化安全

- 虚拟化技术的意义

- ① 虚拟化是支撑云计算的重要技术基石
- ② 虚拟化技术打破了各种物理结构之间的壁垒
- ③ 虚拟化为计算资源、存储资源、网络资源等提供了一个逻辑视图
- ④ 虚拟化是表示计算机资源的抽象方法
- ⑤ 虚拟化技术使得云计算系统能够支持多租户的计算、存储和网络服务的运行



5.2.1 云系统虚拟化安全

- 云计算系统的虚拟化安全问题

1 虚拟机运行保护

在虚拟化环境中,多台虚拟机运行在同一台物理机器上,攻击者有可能对其中某一台虚拟机发起攻击,进而影响到其他虚拟机的运行安全。



两个方面的安全

1、虚拟机运行保护

虚拟机使用的接入认证, 虚拟机的完整性检查, 恶意代码的监控, 虚拟机的高可用性, 以及虚拟机网络连接的攻击防御。

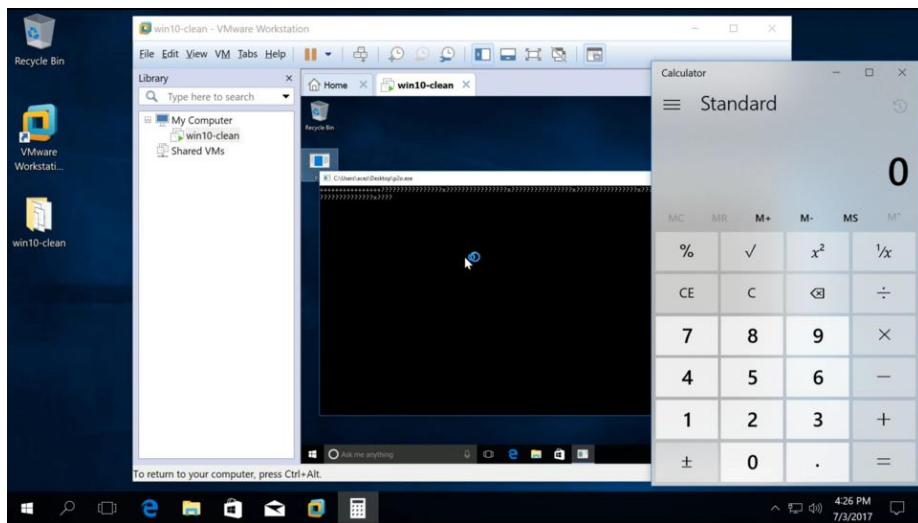
2、用户数据的完整性和隐私性

5.2.1 云系统虚拟化安全

- 云计算系统的虚拟化安全问题

2 虚拟机逃逸

虚拟机逃逸 (Virtual Machine Escape, VME) 是指虚拟机中运行的程序绕过底层,利用宿主机,并控制在主机上运行的其他虚拟机。



利用一个堆溢出漏洞实现VMware虚拟机逃逸

虚拟机逃逸

被认为是对虚拟机的安全性最具有威胁,因为一旦攻击者获得虚拟机监控器的访问权限,就可以任意地访问云计算平台的资源,包括其他租户的资源。

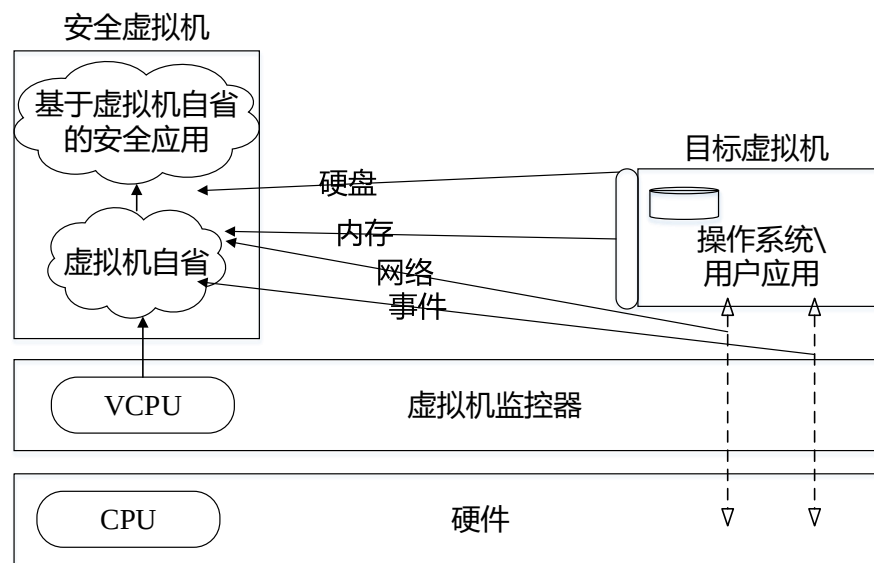
5.2.1 云系统虚拟化安全

- 云计算系统的虚拟化安全问题

3 虚拟机自省

虚拟机自省 (Virtual Machine Introspection, VMI)是指从虚拟机外部监控虚拟机系统内部信息的技术,该技术提供了全新的系统监控技术,从而为保障虚拟化环境的安全性和提高虚拟机的管理能力提供了新的机遇。

由于虚拟机自省技术在解决虚拟化环境下安全问题方面的诸多优点,自该技术被提出以来就得到了广泛的研究。在恶意软件分析、内核完整性检测等其他云安全服务均发挥了重要作用。



虚拟机自省技术的体系架构

5.2.1 云系统虚拟化安全

- 云计算系统的虚拟化安全问题

4 虚拟机迁移

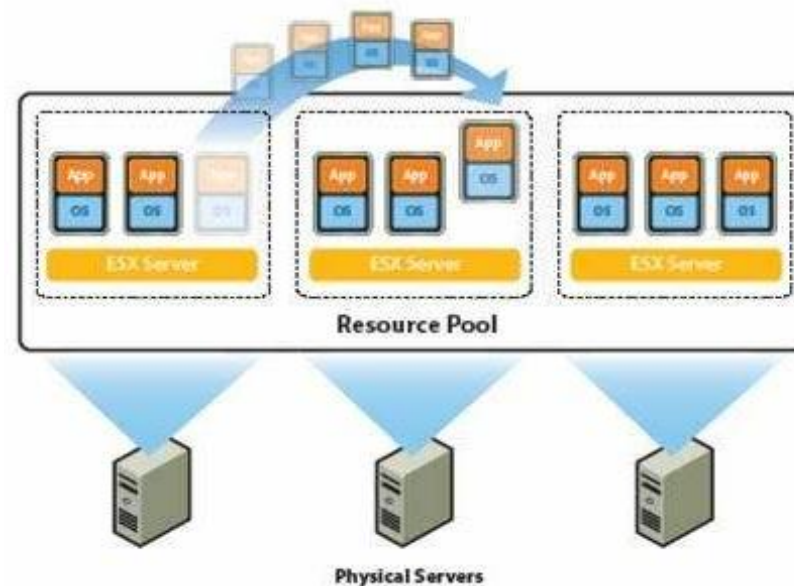
虚拟机迁移 (Virtual Machine Live Migration) 是指将虚拟机从一个物理节点迁移到另外一个物理节点上。虚拟机迁移技术总体分为两种方式：静态迁移（即冷迁移）和在线迁移（即热迁移、动态迁移）。

在云计算环境下,对虚拟机迁移提出了一定的要求:

首先, 云计算环境可能在多种不同类型的虚拟环境基础上构建, 因此要求支持在不同虚拟化环境之间的迁移。

其次, 为保证服务的稳定性, 虚拟机动态迁移也是必须要求之一。

最后, 云计算环境对性能要求较高, 动态迁移应能在较短时间内完成。



5.2.1 云系统虚拟化安全

- 思考题

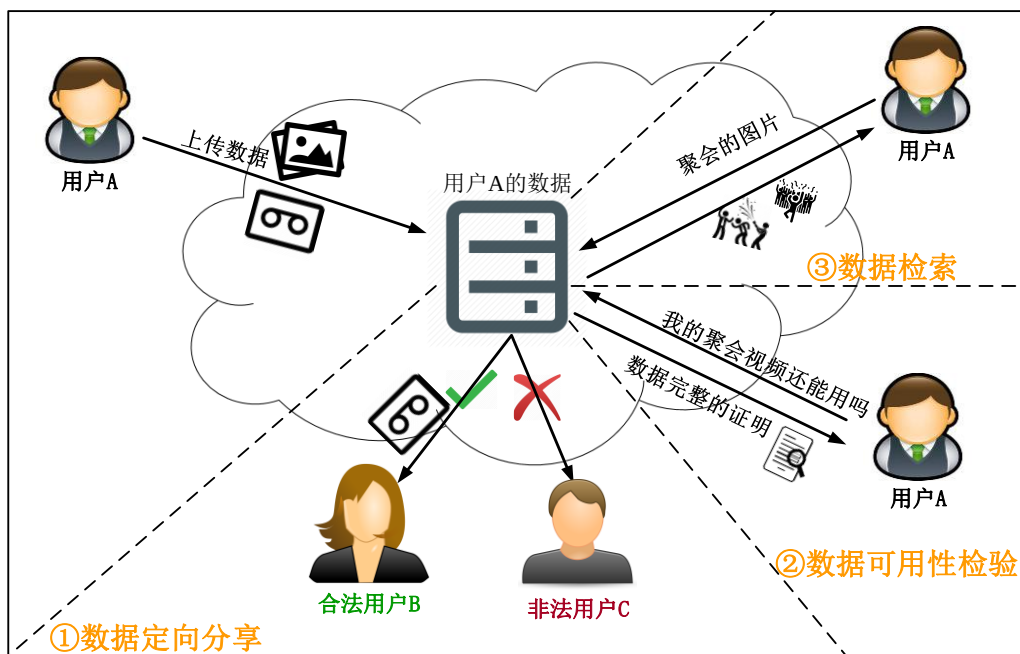
如何有效监控虚拟机是否安全？



5.2.2 云数据存储与计算安全

- 云平台为用户提供的服务

云平台为用户提供的服务可以归结为 **存储** 和 **计算** 两个方面。



安全的云 计算/存储 示例

- **存储**
云需要保证用户存储数据的机密性、完整性等,同时也需要做到访问控制。
- **计算**
云需要保证在确保用户数据的安全性的前提下进行计算,这种安全性可以简单的理解为机密性。

5.2.2 云数据存储与计算安全

- 云平台为用户提供的服务安全

1 细粒度访问控制

访问控制 指的是,当用户将自己的数据存储到云端时,云端需要能够阻止非法的用户访问其他用户的资源和数据等,以及细粒度地控制合法用户的访问权限。

云端要能够根据用户的要求对其数据的访问进行控制。对于云平台来说,他们 **一般使用基于规则（类似于防火墙的过滤规则）的方式** 来对用户的数据进行访问控制。



5.2.2 云数据存储与计算安全

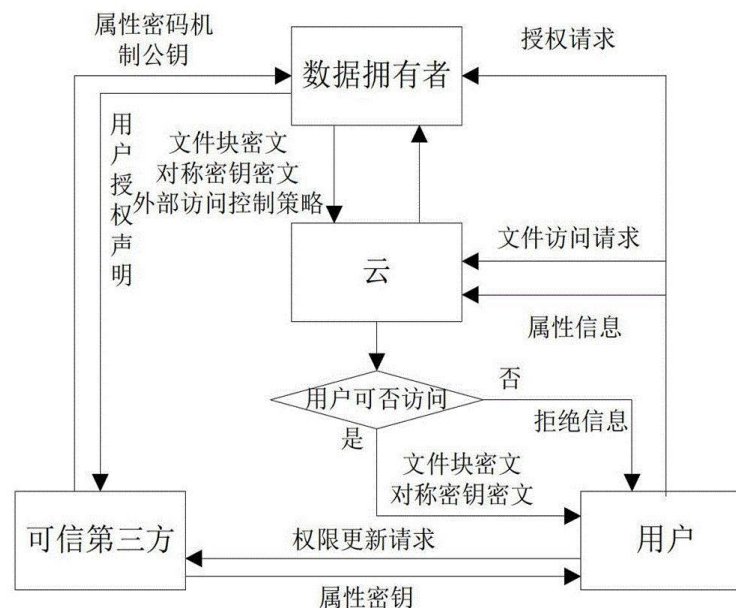
- 云平台为用户提供的服务安全

1 细粒度访问控制

访问控制 指的是,当用户将自己的数据存储到云端时,云端需要能够阻止非法的用户访问其他用户的资源和数据等,以及细粒度地控制合法用户的访问权限。

实际上云服务提供商并不是完全可信的,所以在学术研究上希望通过 **密码学方案** 实现无论云服务提供商是否可信都安全可用的细粒度访问控制。

现阶段对于细粒度访问控制的研究大多基于密码学方案实现,其中以**基于身份加密** (identity based encryption) 和**基于属性加密** (attribute based encryption)的方案最为常见。



5.2.2 云数据存储与计算安全

- 云平台为用户提供的服务安全

2 数据动态完整性

数据动态完整性校验 的目标是让用户无需将所有数据都下载下来就能够检测自己的数据是否完整,或者说是否丢失或遭到篡改。



这一过程在云计算领域存在**两大瓶颈**:

首先,数据的动态更新导致摘要的重新计算,传统的摘要需要用户向服务器获取全部的存储数据,这种负担对于用户而言是无法承受的;

其次,若云不小心损坏了数据,用户无法阻止云通过之前完整性验证交互的消息来冒充和抵赖

。

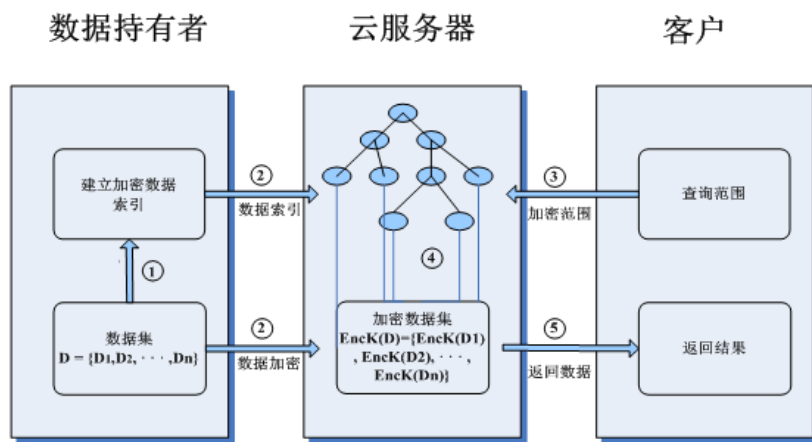
5.2.2 云数据存储与计算安全

- 云平台为用户提供的服务安全

3 密文搜索

密文搜索 是指用户将数据加密后存储到云端,在搜索时提供加密过的关键字,云根据加密过的关键字和加密的数据进行搜索,得到结果后返回给用户的过程。

有两种比较典型的方法:



一、直接对密文进行线性搜索,即对密文中的每个单词进行比对,确认关键字是否在文档中以及统计出现的次数;

二、基于安全索引的密文搜索,先对文档建立关键字索引,然后将文档及索引都加密上传至云端,搜索时从索引查询关键字是否在文档中

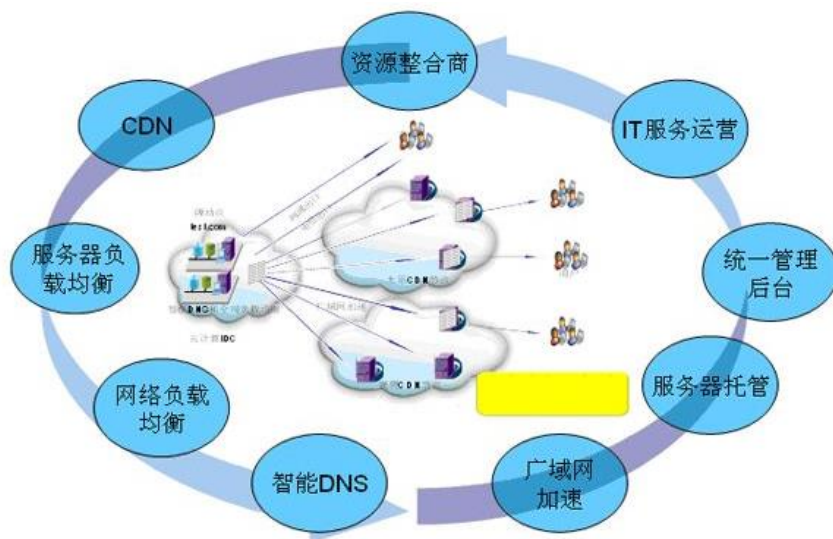
5.2.2 云数据存储与计算安全

- 云平台为用户提供的服务安全

4

其他安全相关技术

云计算安全中还有许多其他实用的安全技术,如隐私数据获取以及读写、安全外包计算。隐私数据获取指用户对数据进行访问的行为进行保护。



目的:

- 一、防止云数据服务商了解用户在访问哪些特定数据;
- 二、隐私数据读写指保护用户对数据的修改行为对云不可见。

5.2.2 云数据存储与计算安全

- 思考题

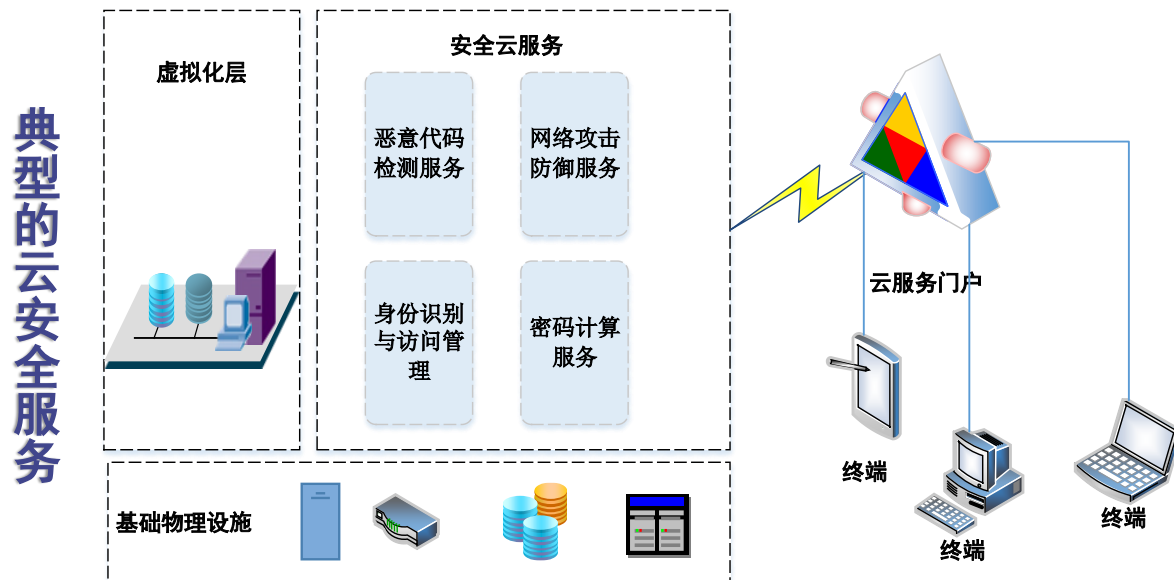
基于密码学的细粒度访问控制的计算开销较高,而相比之下,直接以软件代码的形式做到访问控制十分地便捷和高效。那么,为什么基于密码学地细粒度访问控制仍然有研究和应用的必要呢?



5.2.3 安全即服务

• 云服务

- **云服务** 通常是指任何可以通过云远程访问的IT资源包括计算、存储、网络、应用等资源。
- **云安全服务** 则是云服务提供商为实现用户应用系统的安全目标,为用户提供的服务功能或技术手段,其本质是一类特殊的云服务。



典型的云安全服务主要包括:

- 恶意代码检测服务;
- 网络攻击防御服务;
- 身份识别与访问管理;
- 密码计算服务。

5.2.3 安全即服务

- 恶意代码检测服务

1

云服务恶意代码 是一种程序,通常在用户不觉察的情况下运行,窃取用户数据、破坏计算机的程序和数据、执行某种非授权操作、甚至导致计算机瘫痪。按传播方式,恶意代码可以分成病毒、木马、蠕虫、移动代码和复合型病毒等。

云安全服务不仅能够利用恶意代码特征库对恶意代码进行识别与查杀,更能借助丰富的网络资源以及庞大的网络服务对恶意代码进行实时采集、实时分析甚至实时处理。

服务形式:

- 可以用网站服务的形式提供,接收用户上传的程序代码,实时检测,将检测结果反馈给用户;
- 也可以结合虚拟化系统,实现对虚拟机上程序代码的自动检测和查杀。



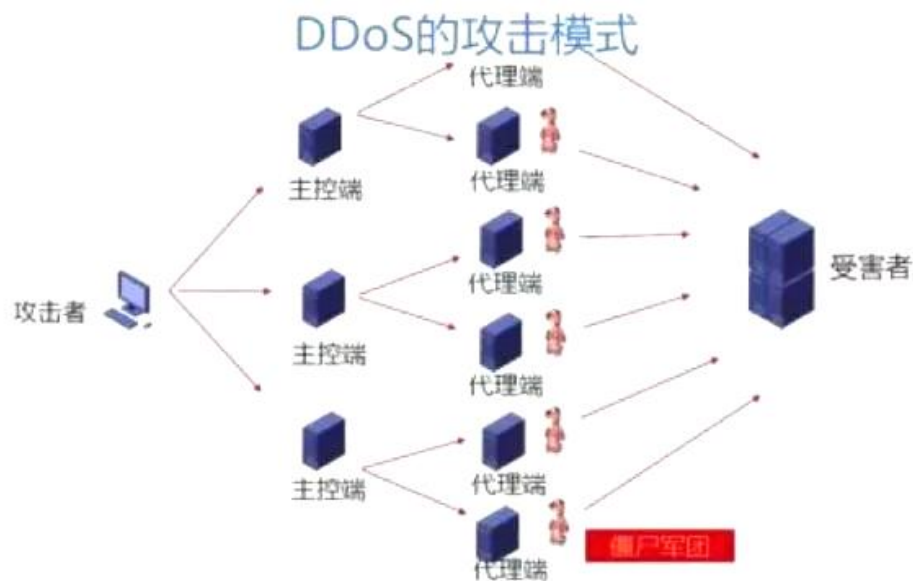
5.2.3 安全即服务

• 网络攻击防御服务

2

网络攻击 是指利用网络系统存在的漏洞和安全缺陷对网络系统的硬件、软件及其数据进行进行的攻击。网络攻击可分为**主动攻击**和**被动攻击**,主动攻击包括篡改消息、伪造消息、恶意代码注入、拒绝服务等,被动攻击包括流量分析、窃听等。

DDoS攻击



云防护



5.2.3 安全即服务

• 身份与访问管理

3

身份与访问管理 (Identity and Access Management, IAM) 通常是一种 Web 服务,可以帮助用户安全地控制对其租用资源的访问。用户可以使用 IAM 实现用户身份管理、身份验证和资源访问控制,例如亚马逊AWS系统的IAM服务。

IAM的功能

- 统一的身份认证和单点登录;
- 细粒度的访问权限配置;
- 基于用户、组、角色的访问控制策略;
- 多重安全级别的身份验证;
- 支持多种云服务应用系统。



5.2.3 安全即服务

• 密码计算服务

4

在传统的信息系统中,密码计算通常使用专门的密码设备来实现,而在云计算环境中,传统的密码设备难以无缝地整合。云服务提供商将密码计算服务与云计算平台进行结合。

服务内容

云服务提供商将密码计算服务与云计算平台进行结合,实现密码计算资源池,大大提高密码计算能力;

通过调度密码设备集群动态调整密码运算能力,为用户提供集中化、虚拟化、透明化的密码计算服务,同时保证服务的稳定性;

通过提供统一服务接口,可以支持不同厂商密码模块的接入;

支持动态添加、删除密码模块,实现了对密码模块的统一集中管理。

5.2.3 安全即服务

- 思考题

作为用户,你在使用云安全服务的过程中存在哪些担忧?

你希望云服务提供商能够提供哪方面新的安全服务?





5.3 云计算安全标准

5.3.1 云安全的国际标准

5.3.2 云安全的国内标准

5.3.1 云安全的国际标准

01 ISO/IEC JTC1 SC27工作组

SC27 作为ISO/IEC JTC1 (国际标准化组织/国际电工委员会的第一联合技术委员会)下专门从事于信息安全标准化的分技术委员会,其相关工作组启动了关于云计算安全及其隐私保护的标准化研究。该工作组明确了云安全和隐私标准研制的三个领域,分别为**信息安全管理,安全技术,身份管理和隐私**。

云的安全性

云服务的安全功能

关注用户访问控制的目的



5.3.1 云安全的国际标准

02 ITU-T FG Cloud

ITU-T (国际电信联盟电信标准分局) 于2010年6月成立了云计算专项组Focus Group Cloud Computing(FG Cloud),FG Cloud致力于从实际的电信角度为云计算提供技术支持,例如电信方面的云安全和云管理。

用户安全威胁主要来源

- 安全责任模糊；用户失去了对托付给云的服务和数据的掌控；选择了失信的云服务提供商；访问控制设置不当和数据泄漏带来的风险。

云服务商安全威胁主要来源

- 数据存储；身份管理；虚拟机隔离；可信级别和责任承担问题；非安全可靠的云计算服务；云服务提供商本身的滥用。



5.3.1 云安全的国际标准

02 ITU-T FG Cloud

ITU-T (国际电信联盟电信标准分局) 于2010年6月成立了云计算专项组Focus Group Cloud Computing(FG Cloud),FG Cloud致力于从实际的电信角度为云计算提供技术支持,例如电信方面的云安全和云管理。

云服务安全建议

- 应当对云服务提供商建立安全评估、安全审计或安全认证/认证计划,以便用户根据其安全要求选择合适的云服务提供商;
- 建议用户在使用云服务前,首先需要根据标准化的规范,和云服务提供商进行安全标准的协商和信任身份等相关标准认证。

云计算安全主要研究方向

- 云框架下的安全体系结构/模型和框架安全; 云服务管理和审计技术; 云服务的连续性保障和灾难恢复机制; 云存储安全; 云数据保护和隐私保护; 账户和身份管理机制; 网络监控和实践响应; 网络安全管理方法; 云服务的可移植性问题等。

5.3.1 云安全的国际标准

03 NIST SAJACC 与 USG Cloud Computing

美国国家标准与技术研究院 (NIST) 提供云技术的相关指导,制定并且推动云相关的技术标准,促进政府和行业内云的相关技术得以有效且安全的使用。NIST的工作有两个方面: 加速推动云计算在各方面的应用 (Standards Acceleration to Jumpstart Adoption of Cloud Computing, SAJACC) ; 构建**美国政府云计算技术的路线图** (USG Cloud Computing) 。



NIST的工作内容

- NIST制定和发布了标准化路线图和关于云计算的特别出版物,通过这些文件的发布,NIST帮助美国政府完成了关于云相关的数据可移植性、互操作性和安全技术的规范化标准。

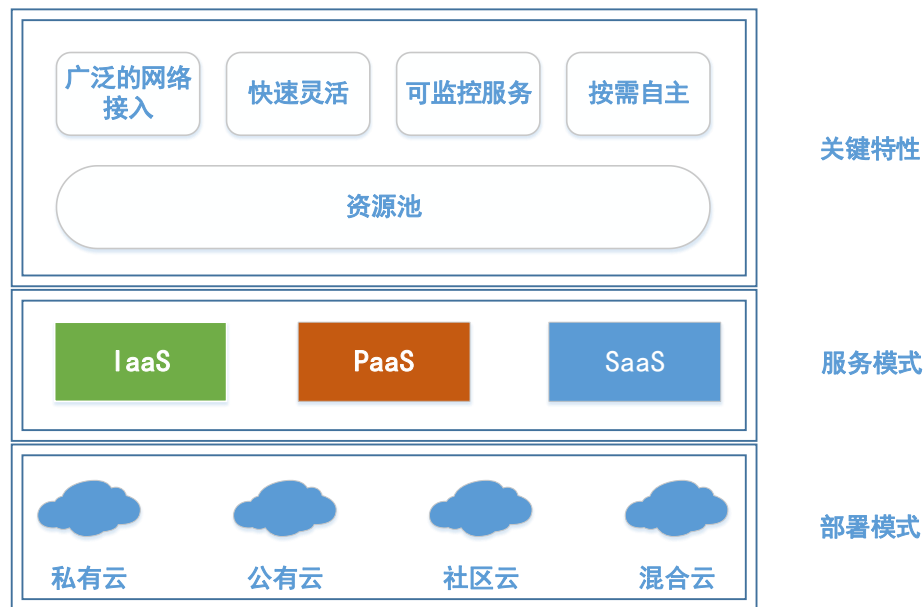
5.3.1 云安全的国际标准

04 云安全联盟 (CSA)

云安全联盟 (Cloud Security Alliance, CSA)是2009年RSA大会上宣布成立的非营利性组织,致力于在云计算环境下提供最佳的安全解决方案。

安全责任范围

- 对于云服务提供商,他们要负责主要的安全性保证,例如平台的安全性;而对于云用户,他们需要负责其在云基础设施上建立的相关服务的安全性。



CSA指南中推荐的云架构

5.3.2 云安全的国内标准

近两年,国内云计算领域相关产业发展迅猛,与此同时,对于云安全和隐私的保护也越发受到大家的重视。据前瞻产业研究院发布的《云安全行业市场分析报告》预测,2014-2019年国内信息安全市场年均复合增长率为16.6%,预计2019年将会达到48.22亿美元。我国云计算行业高速发展,孕育出巨大的安全需求,但是,相对落后的云安全技术尚无法满足市场需求。因此相关云安全的标准化制定显得更为重要。

我国的标准化机构在该方面做出了卓有成效的努力,制定了相关的行业标准;同时,国内的相关研究机构也开始了云安全标准化的研究工作。



5.3.2 云安全的国内标准

01 全国信息安全标准化技术委员会（TC260）

全国信标委云计算标准工作组 全称为“全国信息技术标准化技术委员会云计算标准工作组”，成立于2012年9月20日，负责对云计算领域基础、技术、产品、测评、服务、安全、系统和装备等国家标准的制定和修订工作。

工作内容

工作主要包含：**框架制定、关键技术、服务获取和安全管理**四个部分。

从标准规划来看,包括**云安全的术语、云安全框架、云计算认证和授权标准、云计算授权保护指南、云计算通讯安全标准、基于云计算个人隐私保护、云安全服务测评规范、云计算通信安全标准、云安全服务功能及其规范测试、云平台安全配置指南、云审计要求、云安全的风险评估和管理**等多个方面。



5.3.2 云安全的国内标准

02 中国通信标准化协会

中国通信标准化协会 于2002年12月18日在北京正式成立。该协会是国内企事业单位自愿联合组织起来的,经业务主管部门批准,国家社团登记管理机关登记,开展通信技术领域标准化活动的非营利性法人社会团体。



云安全的行业标准

- 云运维管理接口技术要求;
- 云计算安全框架;
- 公有云服务安全防护检测要求;
- 互联网资源协作服务信息安全管理
系统技术要求和—个CCSA标
准。



5.4 云计算安全法律法规

5.3.1 国际法律法规

5.3.2 国内法律法规

5.4 云安全相关法律法规

近年来云计算平台的各种数据泄漏事件也暴露出云计算本身存在很多安全隐患。云上的信息安全保护不仅是一个技术问题,更是受到社会制度、文化及民众心理等多种因素的影响。这也意味着对于云技术存在的安全问题的解决,不仅要在技术层面上加以完善,更需要结合社会制度来采取相应措施。

在现有的社会体制下,法律作为国家的一个强有力的约束手段,必须成为解决相关安全问题的关键力量。

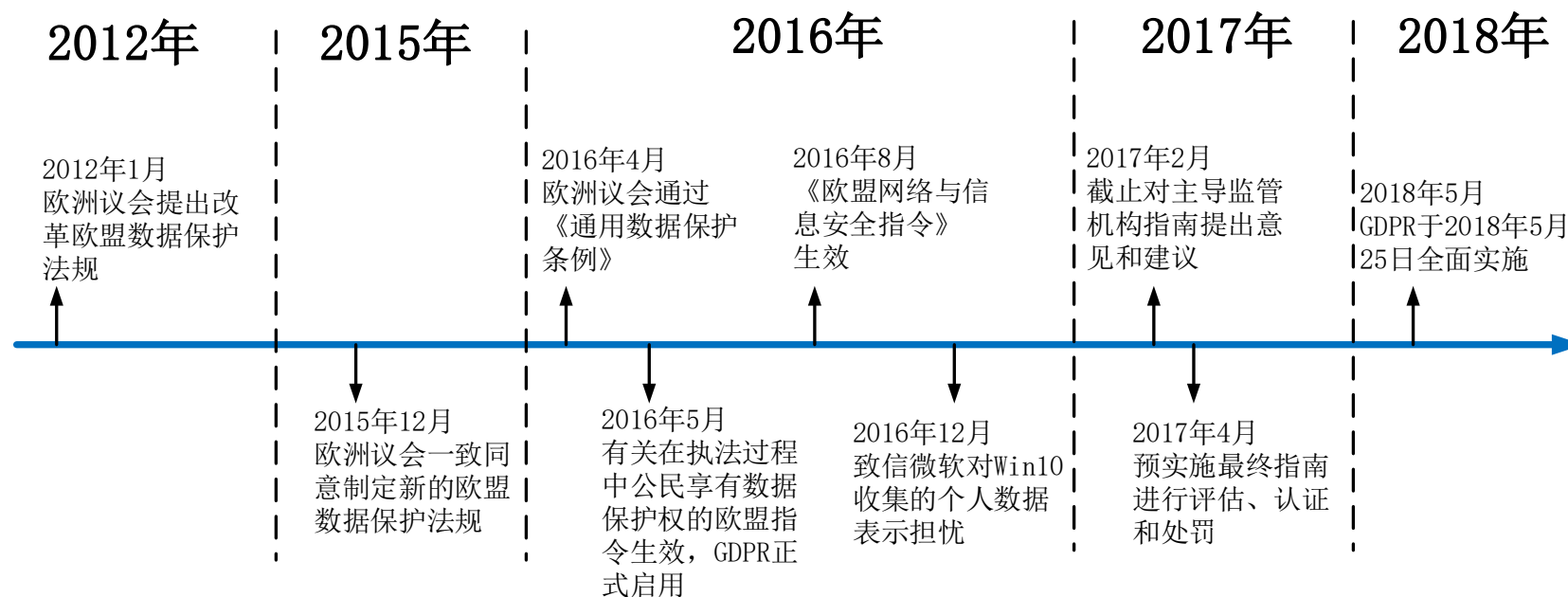
本节将分别从国际和国内两个方面,对部分相关的法律法规进行介绍。



5.4.1 国际法律法规

1 ➤ 欧盟GDPR与云安全

由欧盟理事会和欧盟委员会(EC)联合起草的“**一般数据保护条例**”(GDPR)于2016年5月24日发布,于2018年5月25日生效。



欧盟GDPR发展历程

5.4.1 国际法律法规

1 ➤ 欧盟GDPR与云安全

1. GDPR不仅适用于位于欧盟境内的企业组织机构,也适用于位于欧盟以外的企业组织机构。
2. GDPR法案同样适用于数据控制者和数据处理者。
3. 处理16岁以下儿童的个人数据,必须获得该儿童父母或监护人的同意或授权。
4. 当个人数据已经和收集处理的目的无关、数据主体不希望其数据被处理或数据控制者已没有正当理由保存该数据时,数据主体可以随时要求收集其数据的企业或个人删除其个人数据。
5. 数据控制者应在72小时之内向监管机构报告个人数据的泄漏情况。
6. 为确保数据保护合规并处理数据保护相关事务,数据控制者和数据处理者需设置数据保护官。
7. 不遵守数据隐私法规会受到严厉的法律制裁和巨额的罚款。



5.4.1 国际法律法规

2 ➤ 美国国防部云安全要求指南

2012年7月11日,美国国防部 (DoD) 对外发布了《国防部云计算战略》,该战略旨在通过对商业云计算服务加以利用,使国防部现有的网络应用从重复、烦琐、成本高昂的状态转变到安全且经济高效的状态,其目标是创建一种更灵活、更安全且费效比更低的服务环境,从而对不断变化的任务需求进行快速响应。

➤ 可使用的云服务分类

- 国防部云服务；联邦云服务；商业云服务。

➤ 信息敏感度定义

- 从低等级2的公开信息到高等级6的机密信息。对数据和设备的安全以及网络体系结构分别做了相应的规定。



5.4.1 国际法律法规

2 ➤ 美国国防部云安全要求指南

级别	具体内涵	适用的安全控制	物理位置要求	连接要求	隔离要求	人员安全要求
2	公开信息,或非关键性的业务信息	FedRAMP的中级基线	美国境内、美属地区或国防部辖区	互联网连接	与公共社区进行虚拟或逻辑隔离	国家机关检查和询问 (NACI)
4	受控非涉密信息,或非受控、非涉密但与关键业务相关的信息	第2级基础上,增加对“受控非涉密信息”的特定安全要求	美国境内、美属地区或国防部辖区	通过统一的云访问点连接 NIPRNet (非安全IP路由网)	与公共社区进行虚拟或逻辑隔离,在各个租户的系统之间采用强虚拟隔离方式	单一范围背景调查 (SSBI)、国家机关法律检查和信用调查 (NACLC)、保密协议 (NDA)
5	高度敏感的受控非涉密信息,国家安全系统中非涉密信息	第4级基础上增加对国家安全系统和高敏感信息的特定安全要求	国防部辖区	通过统一的云访问点连接 NIPRNet (非安全IP路由网)	与联邦政府公共社区进行虚拟或逻辑隔离,使用专业的多租户基础设施,与非联邦系统进行物理隔离,在各个租户的系统之间采用强虚拟隔离方式	
6	秘密信息与机密信息	第5级基础上,增加对涉密信息的安全要求	国防部辖区	通过统一的云访问点连接 SIPRNet (机密级IP路由网)	与联邦政府公共社区进行虚拟或逻辑隔离,使用专用的多租户基础设施,与非联邦系统和非涉密系统进行物理隔离,在各个租户的系统之间采用强虚拟隔离方式	机密级人员许可证、保密协议 (NDA)

美国国防部云计算安全要求分级对比

5.4.2 国内法律法规

1 ➤ 《中华人民共和国网络安全法》与云安全

2017年6月1日《中华人民共和国网络安全法》（以下简称《网络安全法》）正式实施,这是我国第一部网络安全的专门性综合立法。

《网络安全法》共有七个章节,一共包含了79项条款,涉及到的内容涵盖了网络空间安全的方方面面。安全法的主要内容由其中的四个章节来概述。

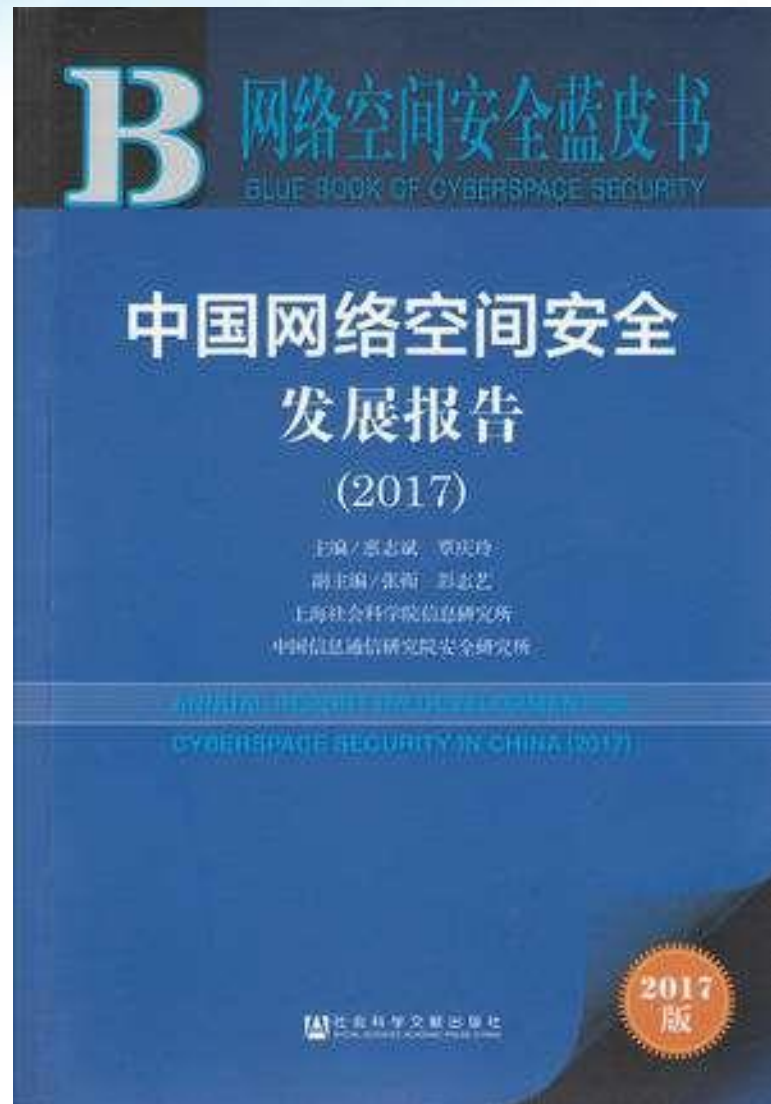
网络运行	信息安全
制度与流程、网络产品与服务、安全评估与信息储存	个人信息的保护与收集、信息的使用与分发
检测和响应	监管处罚
现场监测、全面应急响应、应急演练、风险评估	撤销、罚款停业、吊销执照

安全法四个章节内容概括

5.4.2 国内法律法规

2 ➤ 中国云计算安全政策和法律蓝皮书

2011年中国云计算安全政策与法律工作组发布了第一版《**云安全政策与法律蓝皮书**》,此蓝皮书旨在理清中国云计算发展中所面临的安全风险以及相应的政策法律障碍,为规划国家云计算战略,明确相应法律建设和改革的思路,也为企业发展云计算服务梳理出如何遵从这些法规的模式,帮助用户正确认识云计算法律保护困境,进而切实维护好各方的合法权益。



5.4.2 国内法律法规

2 ➤ 中国云计算安全政策和法律蓝皮书

数据处理机构的位置	管辖权
数据处理机构位于国外, 云用户位于国内	此种服务下,只要用户传输了受进出口管辖的数据即会构成出口,并受云用户所在国的管辖
数据处理机构位于国内, 云用户位于国外	在此种情况下,若云服务提供商向国外云用户传输受进出口管辖的数据则构成出口,并受其所在国家的管辖
数据处理机构和云用户都位于国外	这种情况下一般不受该国的进出口管辖,但是如果在一国的领土上有特别的经营活动,则应该受到该国的管辖
数据处理机构和云用户都在国内或都位于境外的同一国家	这种情况下发生在云服务提供商与其所属国用户之间的数据传输行为一般需受到该国进出口管辖
数据处理机构和云用户在多个国家	此种情形是目前最大的云服务提供商在世界范围内普遍遇到的问题。依据属地管辖的要求,只要数据处理活动发生在某国就应该受该国法律管辖,或者只要与特定国家相关就应该受其管辖

云服务管辖权争议

习 题

1. 云计算的发展给安全领域带来的机遇有哪些？请给出实例加以说明。
2. 云安全所保护的逻辑层面和物理层面的基础设施分别是什么？或者说各自的典型代表分别是什么？
3. 尝试从云计算的不同服务模型的角度出发对比传统信息安全与云安全的异同点。
4. 对比不同服务模型下的云安全需求差异。
5. 对5.1节中列举出的虚拟化安全威胁,应采用什么样的技术进行防范？
6. 调研并指出“同态加密算法”在基于云的安全数据存储和计算中的使用场景。
7. 解释云计算中的安全即服务,并举出几种安全即服务的实例,说明分别利用了云计算的哪些优势。
8. 总结各个云计算安全标准的共同点,并阐述这些共同点的必要性。
9. 总结概括云计算安全法律法规针对的主体,这些主体之间的关系是怎样的？



参考文献

1. Top Threats Working Group. The Treacherous Twelve: Cloud Computing Top Threats in 2016[R].Cloud Security Alliance[CSA].February,2016.
2. 前瞻产业研究院. 2016-2021年中国云安全行业市场前瞻与投资规划分析报告. 深圳: 前瞻产业研究院,2016.
3. 孙召龙,等. 美国国防部云计算安全指南分析 [J]. 信息技术与标准化,2015(12):42-46.
4. 徐保民,李春艳. 云安全深度剖析:技术原理及应用实践[M]. 机械工业出版社, 2016.
5. 李保琿,徐克付,张鹏,等. 虚拟机自省技术研究与应用进展[J]. 软件学报,2016, 27(6):1384-1401.
6. 王仕象. 关于虚拟机迁移技术的应用研究[J]. 科技传播,2012, 4(20):237.
7. 冯登国,张敏,张妍,等. 云计算安全研究[J]. 软件学报,2011, 22(1):71-83.
8. 宫月,李超,吴薇. 虚拟化安全技术研究[J]. 信息网络安全,2016(9):73-78.
9. 卿昱,张剑. 云计算安全技术[M]. 北京:国防工业出版社,2016.
10. 俞能海,郝卓,徐甲甲,等.云安全研究进展综述[J]. 电子学报,2013,41(2):371-381.



感谢倾听